Web Application Penetration Testing & Reconnaissance Report

Trainer / Lead Specialist:	Waseem Abbas Khan (Senior Cybersecurity Specialist, CEI Master Trainer)
Target Enterprise Surface:	NUEXUS Technologies (Private) Limited **Domain:** *.nuexus.com
Testing Environment:	Kali Linux 2026.3 Rolling / BlackArch Linux / Burp Suite Pro / OWASP ZAP
Saved Scan Reports Analyzed:	Burpsuite Report for nuexus.com.html & 2026-11-11-ZAP-Report-.html
Author & Testing Operator:	**Zahid Ullah** (Security Analyst & Penetration Testing Operator)

1. Summary & Legal Context

Modern web application assessments evaluate a unified entry surface typically **TCP 443 (HTTPS)** behind which lies a dynamic interconnected network of client-rendered single-page applications (Next.js), microservice APIs, content distribution networks, and third-party SaaS integrations. As emphasized in the curriculum by Trainer Waseem Abbas Khan, scanning a port reveals minimal insight; comprehensive security evaluation requires in-depth HTTP transaction analysis, search engine reconnaissance, multi-source subdomain discovery, and dual-scanner automated auditing.

This deliverable consolidates all empirical findings from the assessment against nuexus.com (*.nuexus.com). It directly integrates both standalone machine-generated reports saved during testing: the Burp Suite Scanner Report (149 KB) and the comprehensive OWASP ZAP by Checkmarx Scanning Report (10.9 MB, 50 alerts), offering actionable technical conclusions.

LEGAL & OPERATIONAL BOUNDARY: Reconnaissance sits at an essential legal boundary under Pakistan's Prevention of Electronic Crimes Act (PECA 2016) and international cyber law. Passive reconnaissance (search queries, certificate transparency records, public DNS archives) touches zero target infrastructure and is completely lawful. Active reconnaissance transmits packets directly to endpoints, generating server logs and firewall alerts. Conducting active scanning without explicit written authorization constitutes a criminal offense. All operations documented herein were executed in strict adherence to authorized corporate Rules of Engagement.

2. Task 1

Scope Document & Rules of Engagement

2.1 Asset Boundaries and Technical Rules Matrix

Asset / Target Domain	Classification	Boundaries & Rules Applied
https://www.nuexus.com	In-Scope (Primary)	Full crawl, passive audit, manual parameter testing, Repeater fuzzing.
https://app.nuexus.com	In-Scope (Production App)	Grey-box access with test credentials; authorization boundary checks.
https://api.nuexus.com	In-Scope (API Surface)	REST API fuzzing, endpoint enumeration, CORS policy verification.
***.nuexus.com (Subdomains)**	In-Scope (Subject to Clause)	Enumerated hosts subject to mandatory Host Verification Break-Glass protocol.
career.nuexus.com	Strictly Out-of-Scope	Explicitly excluded HR portal; zero automated or manual packet generation.
Third-Party SaaS (*.cloudflare.com, *.vercel.com)	Strictly Out-of-Scope	Multi-tenant cloud infrastructure; attacking hosting providers is unlawful.
Employee Personal Accounts & Devices	Strictly Out-of-Scope	Zero social engineering, phishing, vishing, or personal device targeting.

THE WILDCARD BREAK-GLASS PROTOCOL: A wildcard scope (*.nuexus.com) introduces significant risk because DNS zones frequently point subdomains to shared cloud hosting, ephemeral branches, or abandoned SaaS platforms. To prevent unlawful collateral testing, our engagement enforces a strict Break-Glass Protocol: Whenever a new host is discovered, automated traffic is frozen until ownership is cross-referenced with registrar records and confirmed in writing by Technical Authority Waseem Abbas Khan. Emergency halt code: 'ABORT-NUEXUS-ALPHA-STOP'.

3. Task 2

Google Dorking Vulnerability Assessment

Google Dorking utilizes advanced search engine directives to interrogate indexed attack surfaces without sending packets to the target servers. Six targeted dorks were constructed and evaluated against nuexus.com:

Operator / Dork Query	Category	Finding Status	Remediation & Defensive Control
site:nuexus.com	Baseline Recon	EXPOSURE: Direct corporate emails, phone numbers, and policy links exposed.	Use generic aliases; sanitize personal contact data on public pages.
site:nuexus.com filetype:pdf	Document Leak	EXPOSURE: 5+ internal technical playbooks indexed under /playbooks/.	Apply 'X-Robots-Tag: noindex' or restrict playbooks behind auth.
site:nuexus.com intitle:"index of"	Directory Traversal	CLEAN: Directory browsing disabled across web servers.	Retain 'Options -Indexes' across all Apache/Nginx web roots.
site:nuexus.com inurl:admin OR inurl:login	Admin Surface	CLEAN: Administrative dashboards not exposed to public indexing.	Enforce SSO, MFA, and IP access-lists for management interfaces.
site:nuexus.com ext:env OR ext:conf	Config Disclosure	CLEAN: Zero configuration files, secrets, or logs indexed.	Enforce strict .gitignore checks and deny rules in web servers.
site:nuexus.com -www	Subdomain Recon	EXPOSURE: Discovered live production portal 'app.nuexus.com'.	Configure robots.txt disallow rules on application portals if non-public.

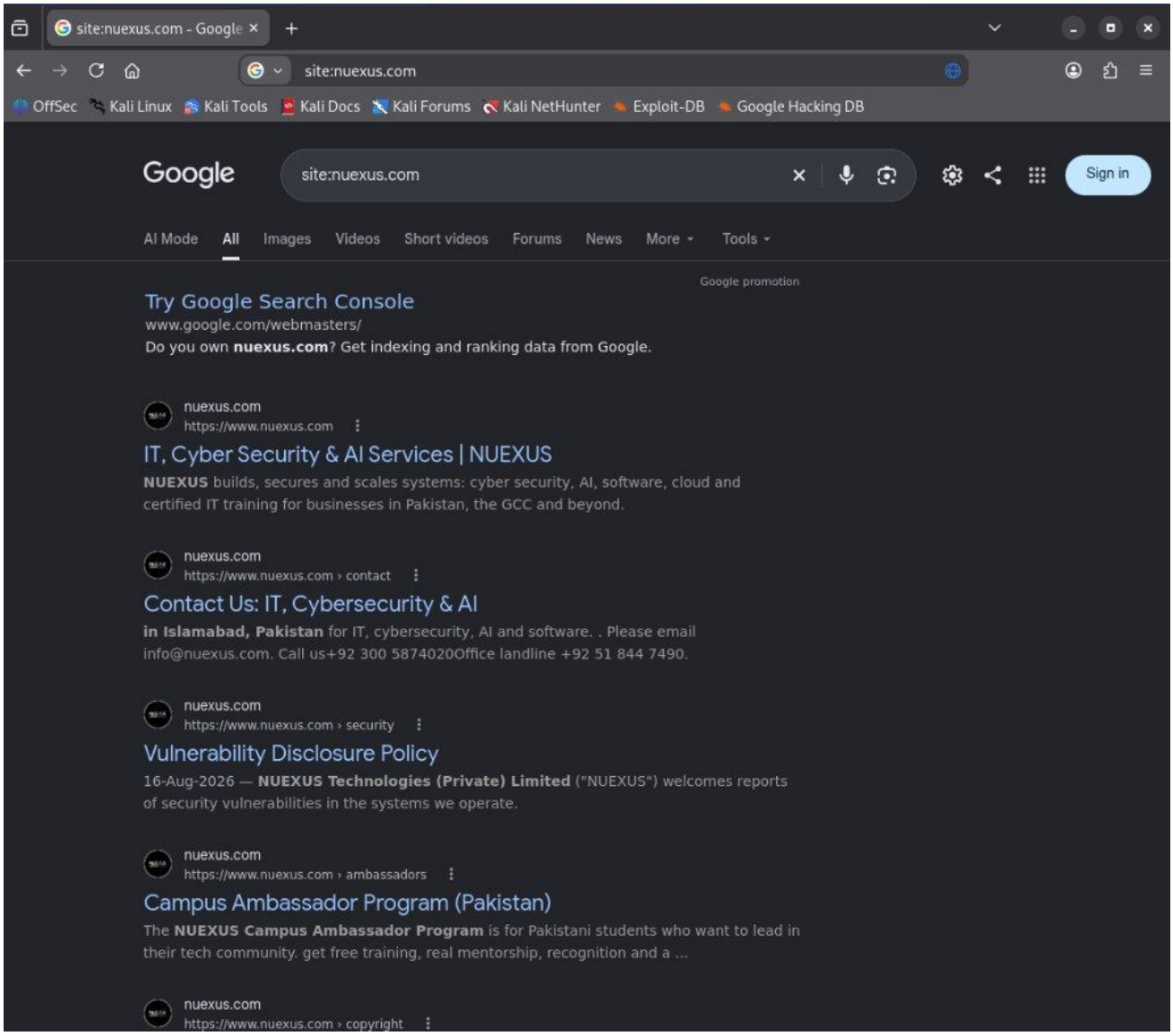


Figure 2.1: Baseline Google Dork query (site:nuexus.com) disclosing contact metadata and corporate policy indexes.

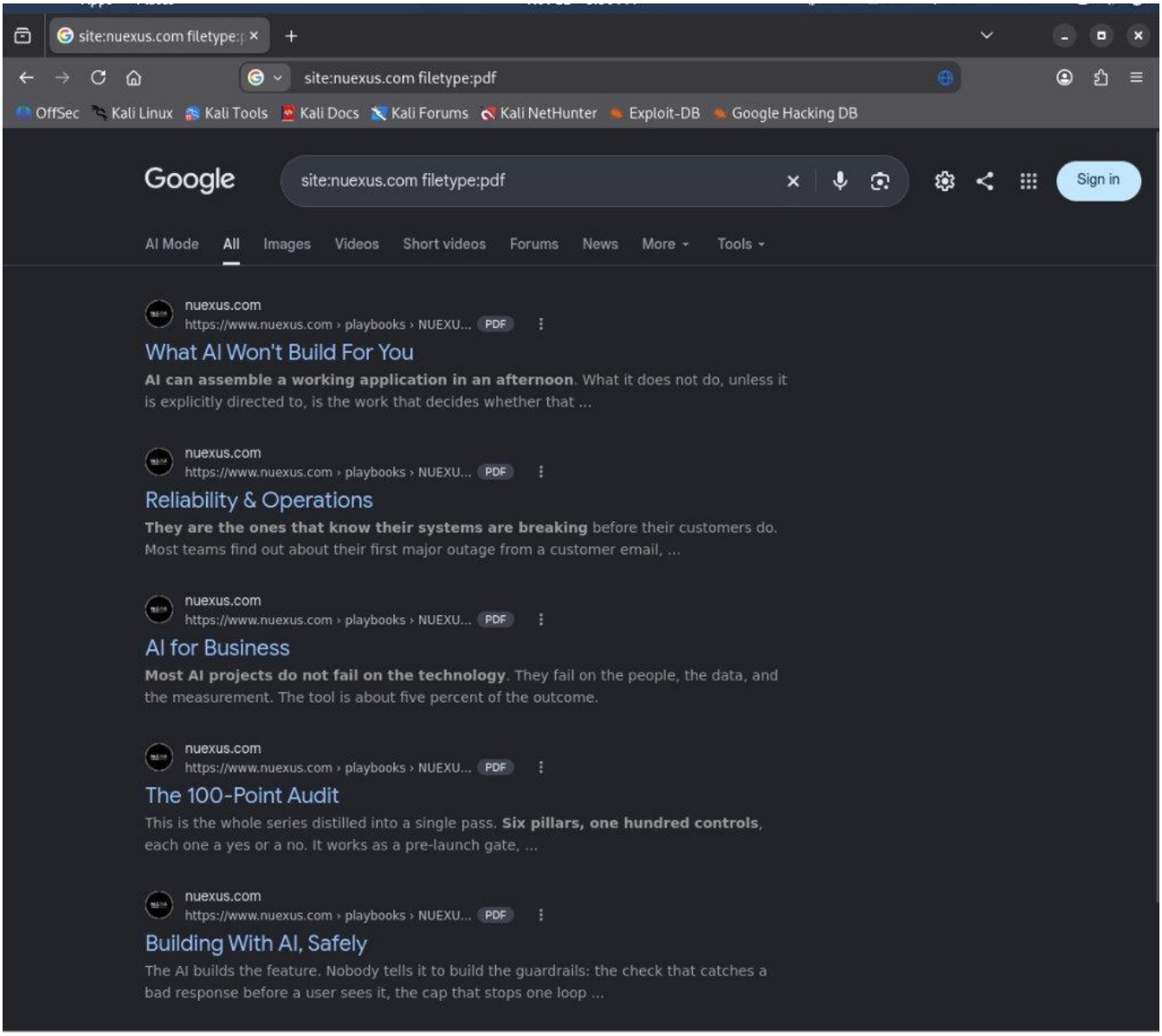


Figure 2.2: Document leakage dork (site:nuexus.com filetype:pdf) revealing 5+ indexed proprietary playbooks.

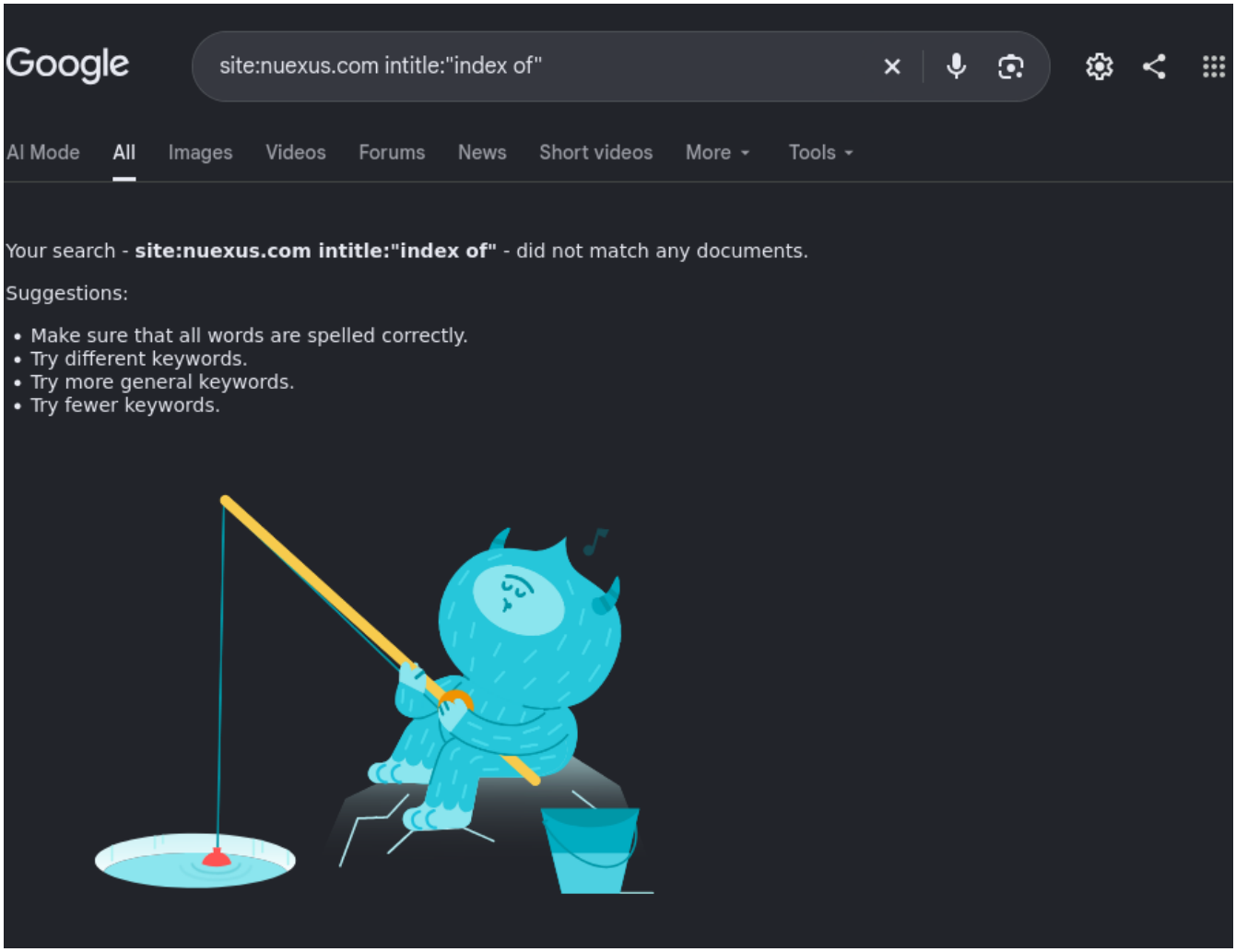


Figure 2.3: Verification of directory browsing protection (site:nuexus.com intitle:"index of").

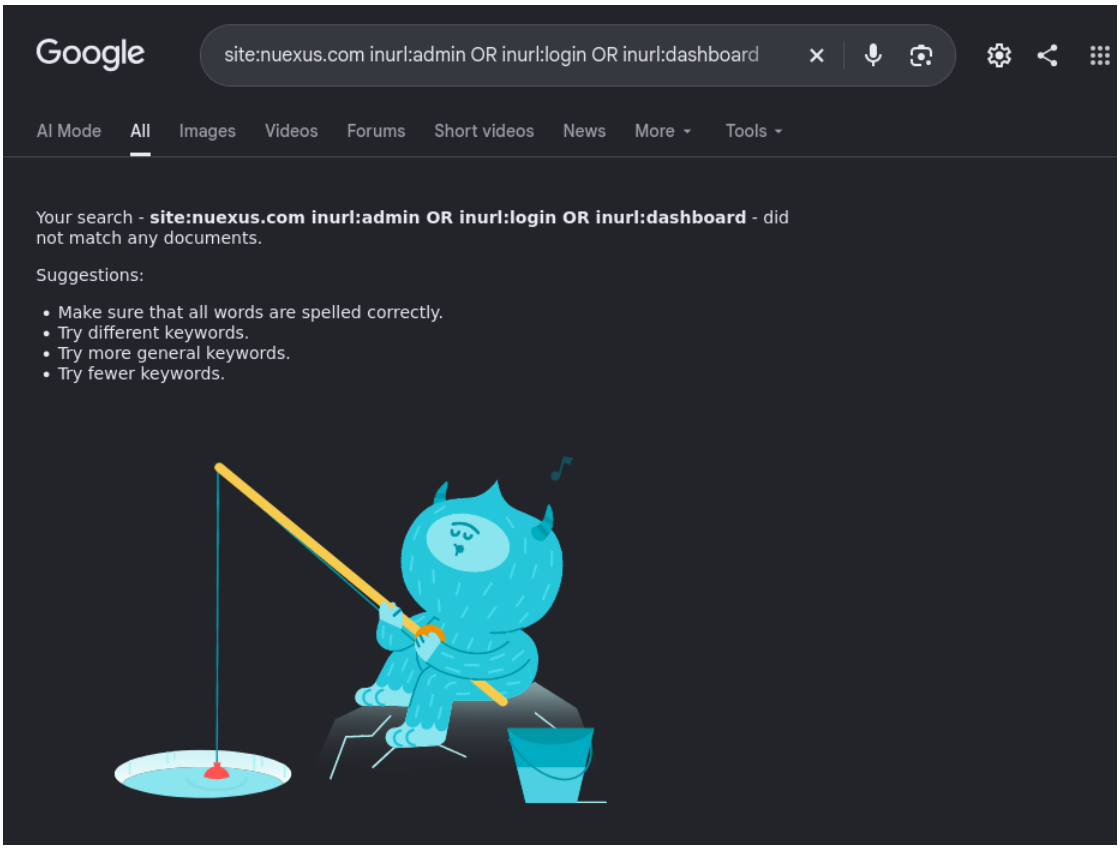


Figure 2.4: Administrative interface interrogation confirming absence of indexed administrative panels.

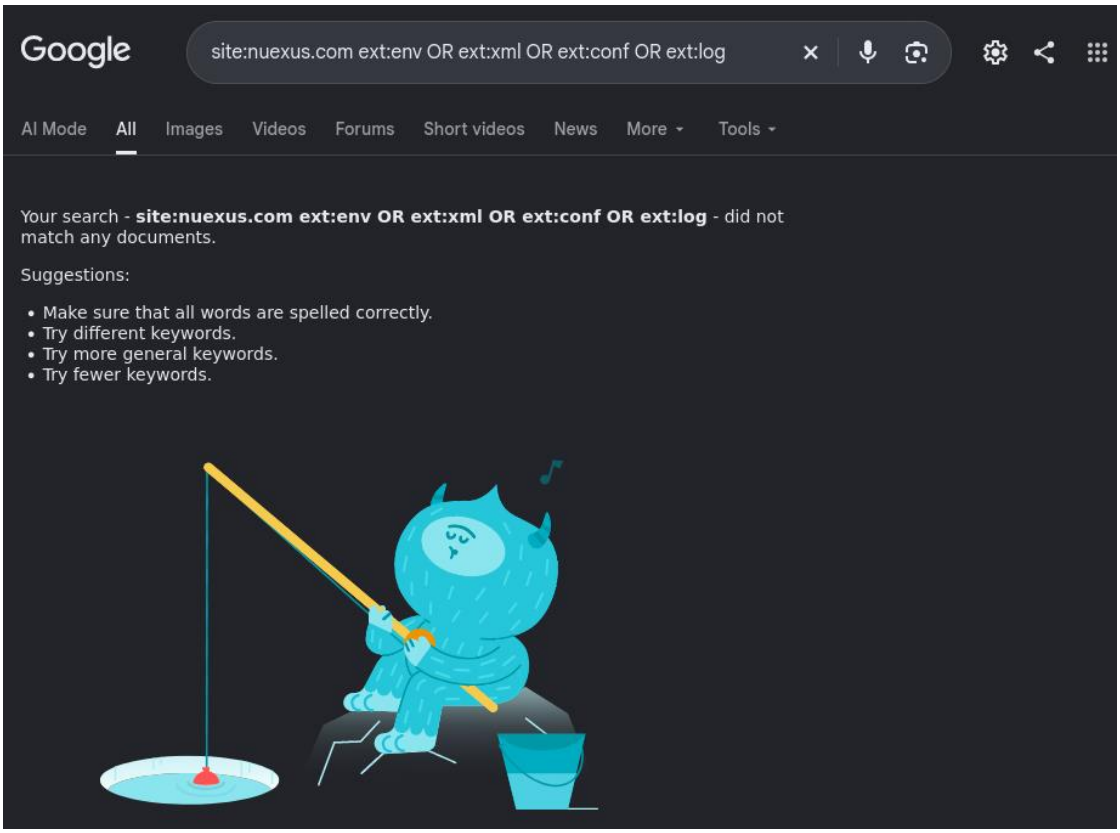


Figure 2.5: Configuration exposure check confirming environment files are safely excluded from indexing.

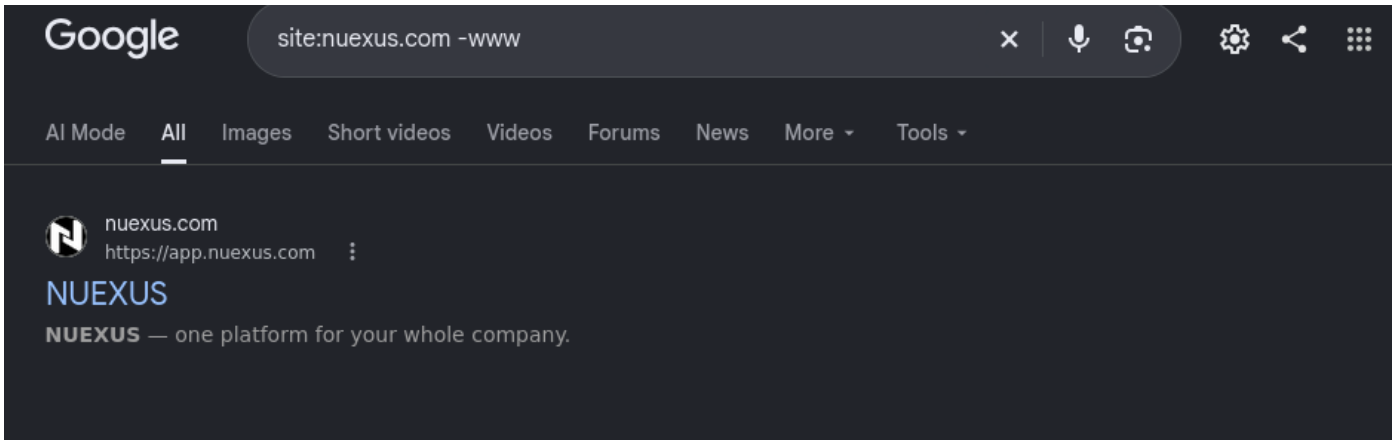


Figure 2.6: Subdomain discovery via exclusion operator (site:nuexus.com -www) identifying app.nuexus.com.

4. Task 3: Multi-Engine Subdomain Reconnaissance & Reconciliation (Weight: 25%)

Subdomain enumeration identifies development branches, staging hosts, and internal portals. Three tools were executed: subfinder (24 hosts via CT logs), assetfinder (7 core production hosts), and theHarvester (20 hosts + 10 IPs). All candidates were deduplicated into subs.txt and actively resolved with httpx-toolkit:

FQDN Subdomain	Resolved IP	Status Code	Detected Technology	Security Observation
https://nuexus.com	172.67.201.8	308 Redirect	Cloudflare, HSTS, HTTP/3, Vercel	Permanent redirect to www.nuexus.com
https://www.nuexus.com	188.114.97.6	200 OK	Cloudflare, Vercel, HSTS, HTTP/3	Primary corporate production landing portal
https://app.nuexus.com	104.21.85.21	200 OK	Bootstrap, Google Sign-in, Vercel	Authenticated enterprise platform portal
https://autodiscover.nuexus.com	104.21.85.21	200 OK	Cloudflare, Google Cloud CDN, HSTS	Mail client autodiscovery active endpoint
https://autoconfig.nuexus.com	188.114.97.6	200 OK	Cloudflare, Google Cloud CDN, HSTS	Email configuration autoconfig service
https://mta-sts.nuexus.com	76.76.21.61	200 OK	Vercel Edge, HSTS	Strict Transport Security email policy daemon
https://recruit.nuexus.com	104.21.85.21	526 Invalid SSL	Cloudflare, HTTP/3	Origin server backend SSL certificate invalid/expired
https://assessments.nuexus.com	188.114.97.6	526 Invalid SSL	Cloudflare, HTTP/3	Origin SSL handshake failed behind Cloudflare
https://api.nuexus.com	188.114.97.6	526 Invalid SSL	Cloudflare, HTTP/3	Backend API endpoint origin certificate error

CRITICAL ARCHITECTURAL FINDING (HTTP 526)

The identification of HTTP 526 status codes on *api.nuexus.com*, assessments.nuexus.com, and recruit.nuexus.com highlights a critical origin configuration flaw. While Cloudflare successfully accepts client TLS connections at the edge, the origin server's backend TLS certificate is self-signed, mismatched, or expired. Under Cloudflare's 'Full (Strict)' mode, this severs client traffic. Remediation requires provisioning valid Cloudflare Origin CA certificates or Let's Encrypt certificates on the origin backend.

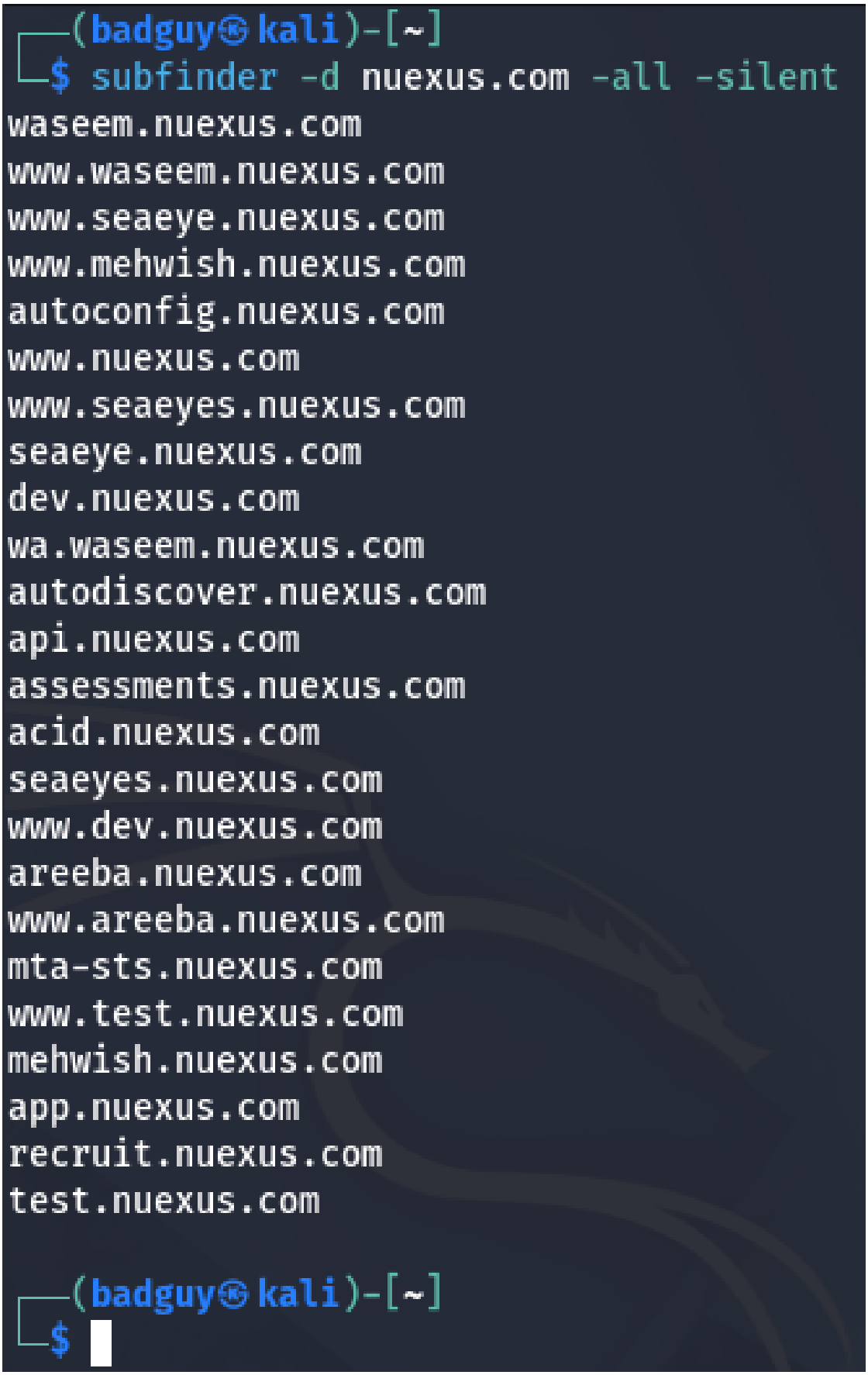


Figure 3.1: Subdomain enumeration via subfinder discovering 24 distinct hosts.

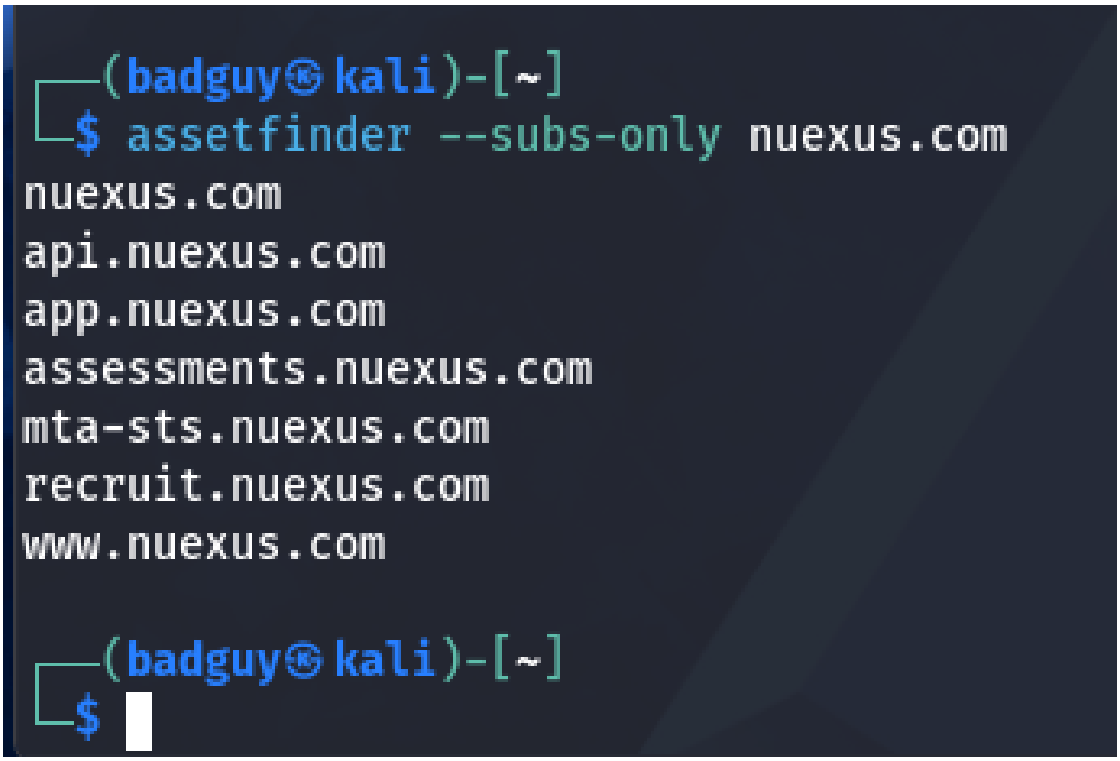


Figure 3.2: Rapid asset discovery via assetfinder identifying 7 core subdomains.

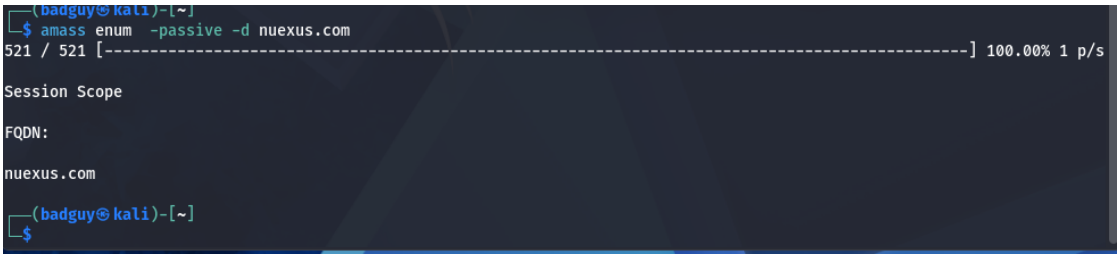


Figure 3.3: Amass baseline enumeration showing session scope and query execution.

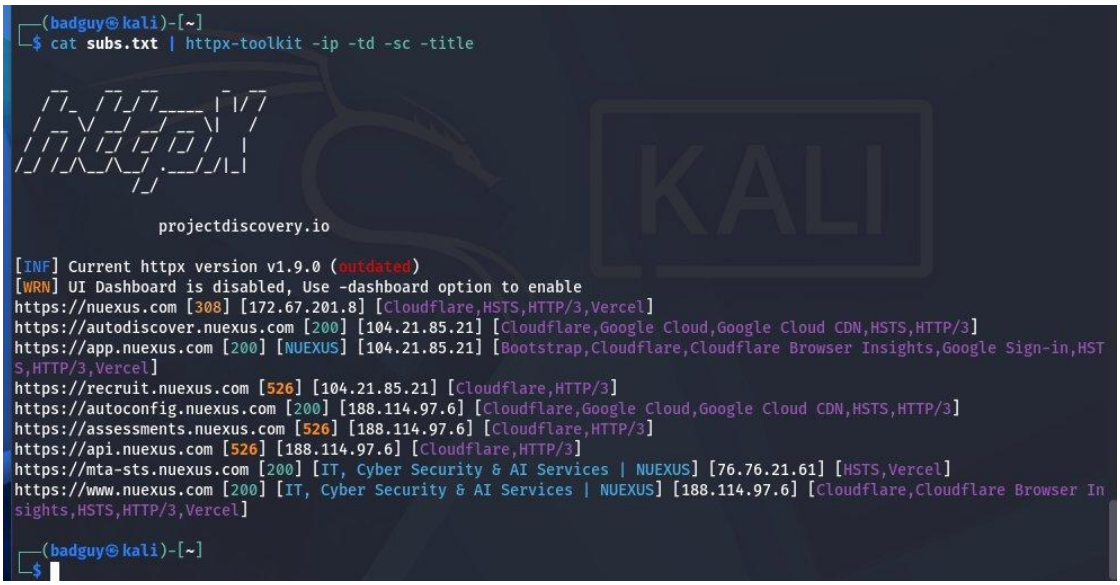


Figure 3.4: Active host probe via httpx-toolkit validating live HTTP 200 services and HTTP 526 origin errors.

5. Task 4

Automated Web Scanner Comparative Analysis

To provide empirical depth, this assessment contrasts the two official machine-generated audit reports produced during the lab:

• Burp Suite Scanner Report **(Burpsuite Report for nuexus.com.html)**

• OWASP ZAP by Checkmarx Scanning Report (2026-11-11-ZAP-Report-.html, 10.9 MB, 50 Alerts across 2 sites)

5.1 Vulnerability Severity & Alert Metrics Breakdown

Severity Rating	Burp Suite Scanner Report (Saved HTML)	OWASP ZAP Scanning Report (Saved HTML)
High Severity	0 Issues (0%)	6 Alert Types / 26 Instances (12.0%)
Medium Severity	0 Issues (0%)	9 Alert Types / 33 Instances (18.0%)
Low Severity	1 Issue: Strict Transport Security not enforced	7 Alert Types / 8 Instances (14.0%)
Informational	11 Issues (CSP, emails in chunks, cacheable)	28 Alert Types / 1,350+ Instances (56.0%)
Total Identified	12 Issues Recorded	50 Distinct Alert Types (100%)
Primary Target Scope	https://www.nuexus.com (11) & cloudflareinsights (1)	https://www.nuexus.com (48) & cloudflareinsights (2)

5.2 Findings Deep-Dive: Architectural Roots of Divergence

Vulnerability Category	Burp Suite Report Finding	OWASP ZAP Report Finding
DOM-based Cross-Site Scripting (XSS)	Not Detected. Burp operated as a passive proxy inspection engine during manual browsing, reviewing static responses.	HIGH SEVERITY (11 taint flows, 2 innerHTML). Headless Firefox dynamically executed Next.js code, tracing sources to Element.innerHTML sinks.
Content Security Policy (CSP) Directives	INFORMATIONAL. Flagged CSP allows untrusted script/style execution on root /.	MEDIUM SEVERITY (5 instances). Flagged systemic unsafe-eval, unsafe-inline, and wildcard directives across 5 endpoints.
Email Address Disclosure	INFORMATIONAL (7 distinct instances). Cataloged exact script chunk IDs (/1528-..., /2039-..., /contact, /privacy-policy).	INFORMATIONAL. Aggregated under generic Information Disclosure / Sensitive Information in URL alert.
CORS Preflight & Verb Tampering	Wildcard origin Access-Control-Allow-Origin: * identified on OPTIONS / preflight	Cross-Domain Misconfiguration (6 instances) and Specify postMessage

	in Repeater.	targetOrigin (1 instance).

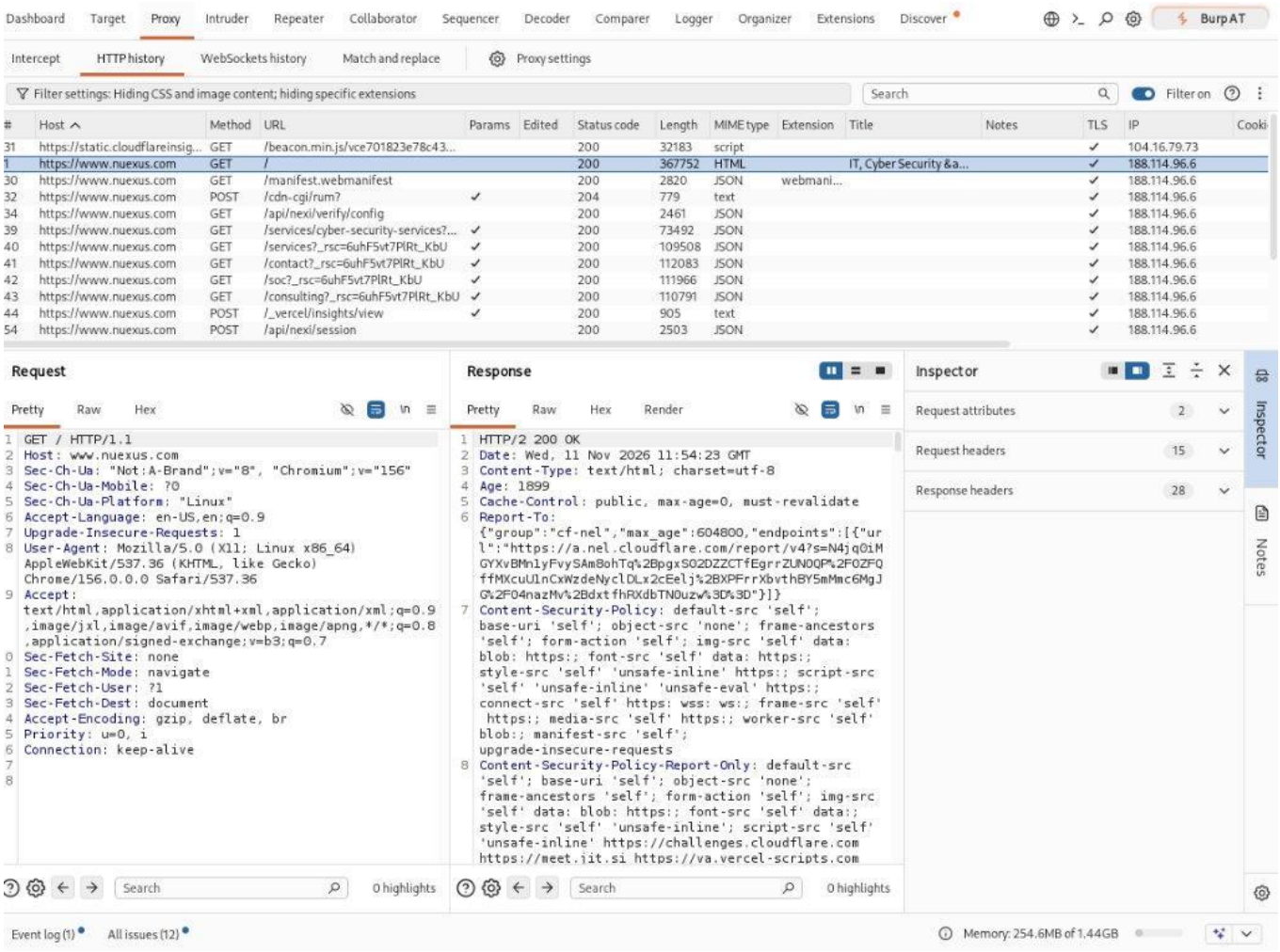


Figure 4.1: Client-server request/response model inspection in Burp Proxy HTTP history (Outcome #1).

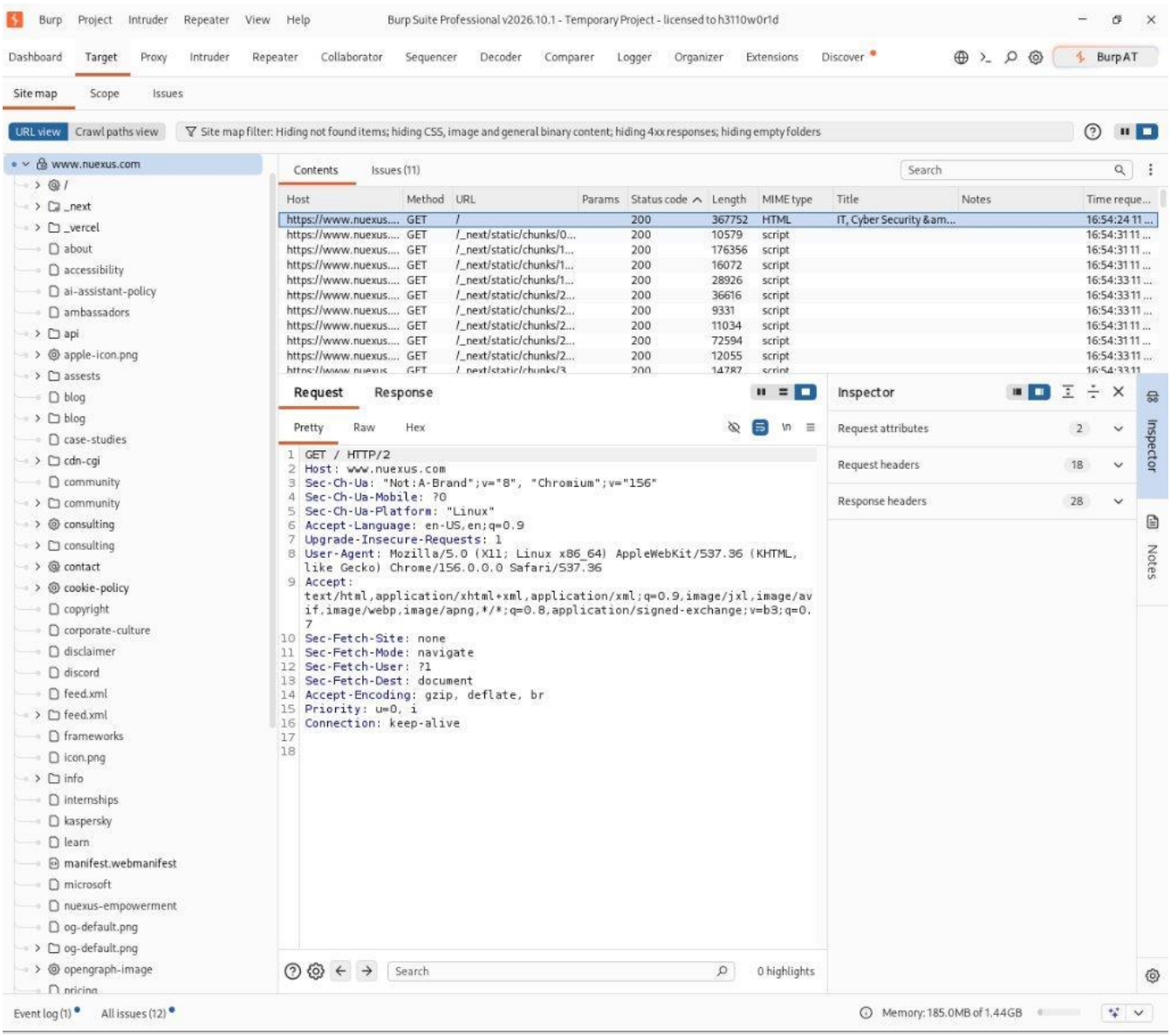


Figure 4.2: Application endpoint modeling in Burp Target Site Map displaying Next.js and Vercel routing.

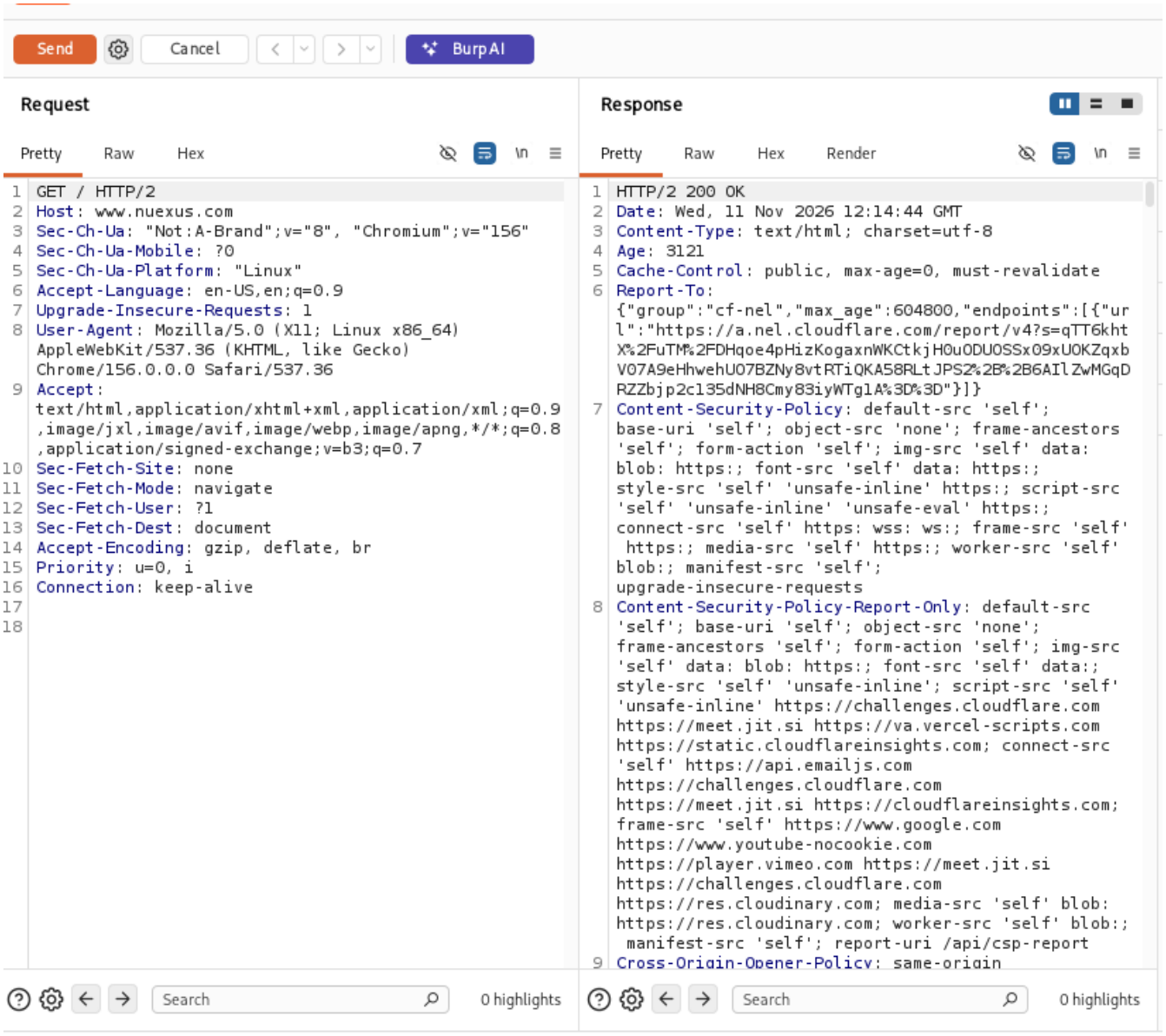


Figure 4.3: Manual baseline evaluation of GET / HTTP/2 request and response in Burp Repeater.

Request

Pretty Raw Hex

```
1  OPTIONS / HTTP/2
2  Host: www.nuexus.com
3  Sec-Ch-Ua: "Not:A-Brand";v="8", "Chromium";v="156"
4  Sec-Ch-Ua-Mobile: ?0
5  Sec-Ch-Ua-Platform: "Linux"
6  Accept-Language: en-US,en;q=0.9
7  Upgrade-Insecure-Requests: 1
8  User-Agent: Mozilla/5.0 (X11; Linux x86_64)
   AppleWebKit/537.36 (KHTML, like Gecko)
   Chrome/156.0.0.0 Safari/537.36
9  Accept:
   text/html,application/xhtml+xml,application/xml;q=0.9
   ,image/jxl,image/avif,image/webp,image/apng,*/*;q=0.8
   ,application/signed-exchange;v=b3;q=0.7
10 Sec-Fetch-Site: none
11 Sec-Fetch-Mode: navigate
12 Sec-Fetch-User: ?1
13 Sec-Fetch-Dest: document
14 Accept-Encoding: gzip, deflate, br
15 Priority: u=0, i
16
17
```

Search 0 highlights

Response

Pretty Raw Hex Render

```
1  HTTP/2 204 No Content
2  Date: Wed, 11 Nov 2026 12:17:40 GMT
3  Access-Control-Allow-Methods: OPTIONS, GET, HEAD
4  Access-Control-Allow-Origin: *
5  Age: 0
6  Cache-Control: public, max-age=0, must-revalidate
7  Content-Disposition: inline
8  Content-Security-Policy: default-src 'self';
   base-uri 'self'; object-src 'none'; frame-ancestors
   'self'; form-action 'self'; img-src 'self' data:
   blob: https:; font-src 'self' data: https:;
   style-src 'self' 'unsafe-inline' https:; script-src
   'self' 'unsafe-inline' 'unsafe-eval' https:;
   connect-src 'self' https: wss: ws:; frame-src 'self'
    https:; media-src 'self' https:; worker-src 'self'
   blob:; manifest-src 'self';
   upgrade-insecure-requests
9  Content-Security-Policy-Report-Only: default-src
   'self'; base-uri 'self'; object-src 'none';
   frame-ancestors 'self'; form-action 'self'; img-src
   'self' data: blob: https:; font-src 'self' data:;
   style-src 'self' 'unsafe-inline'; script-src 'self'
   'unsafe-inline' https://challenges.cloudflare.com
   https://meet.jit.si https://va.vercel-scripts.com
   https://static.cloudflareinsights.com; connect-src
   'self' https://api.emailjs.com
   https://challenges.cloudflare.com
   https://meet.jit.si https://cloudflareinsights.com;
   frame-src 'self' https://www.google.com
   https://www.youtube-nocookie.com
   https://player.vimeo.com https://meet.jit.si
   https://challenges.cloudflare.com
   https://res.cloudinary.com; media-src 'self' blob:
   https://res.cloudinary.com; worker-src 'self' blob:;
    manifest-src 'self'; report-uri /api/csp-report
10 Cross-Origin-Opener-Policy: same-origin
11 Permissions-Policy: camera=(), microphone=(),
   geolocation=(), interest-cohort=()
12 Referrer-Policy: strict-origin-when-cross-origin
13 Server: cloudflare
```

Search 0 highlights

*Figure 4.4: Verb tampering via OPTIONS request uncovering permissive wildcard CORS (Access-Control-Allow-Origin: *).*

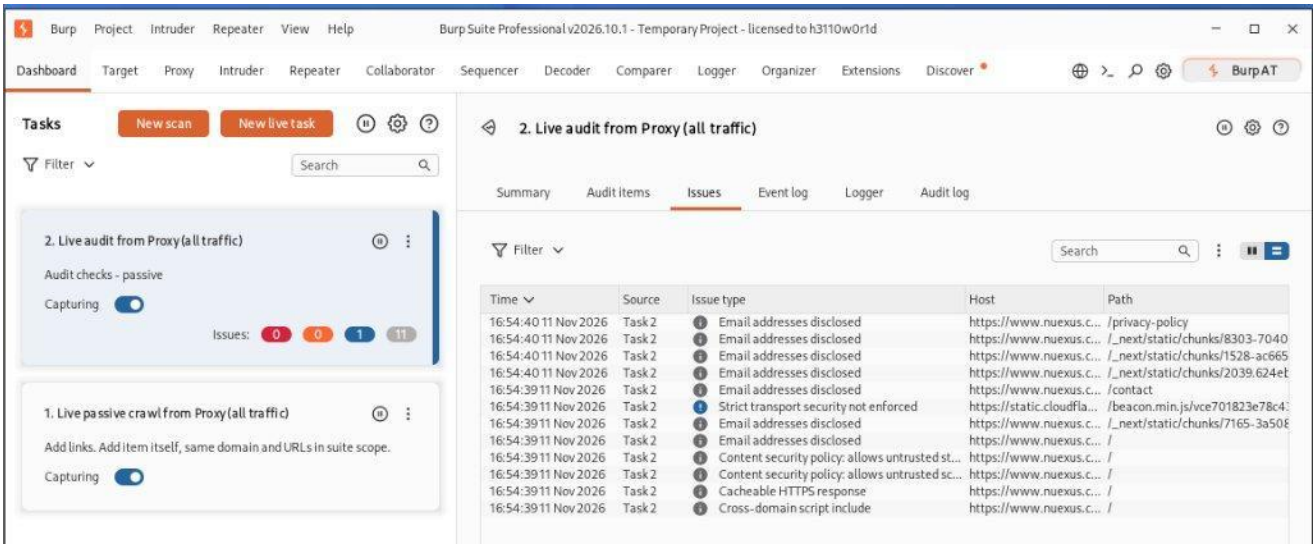


Figure 4.5: Burp Dashboard issue activity detailing 12 passive vulnerabilities.

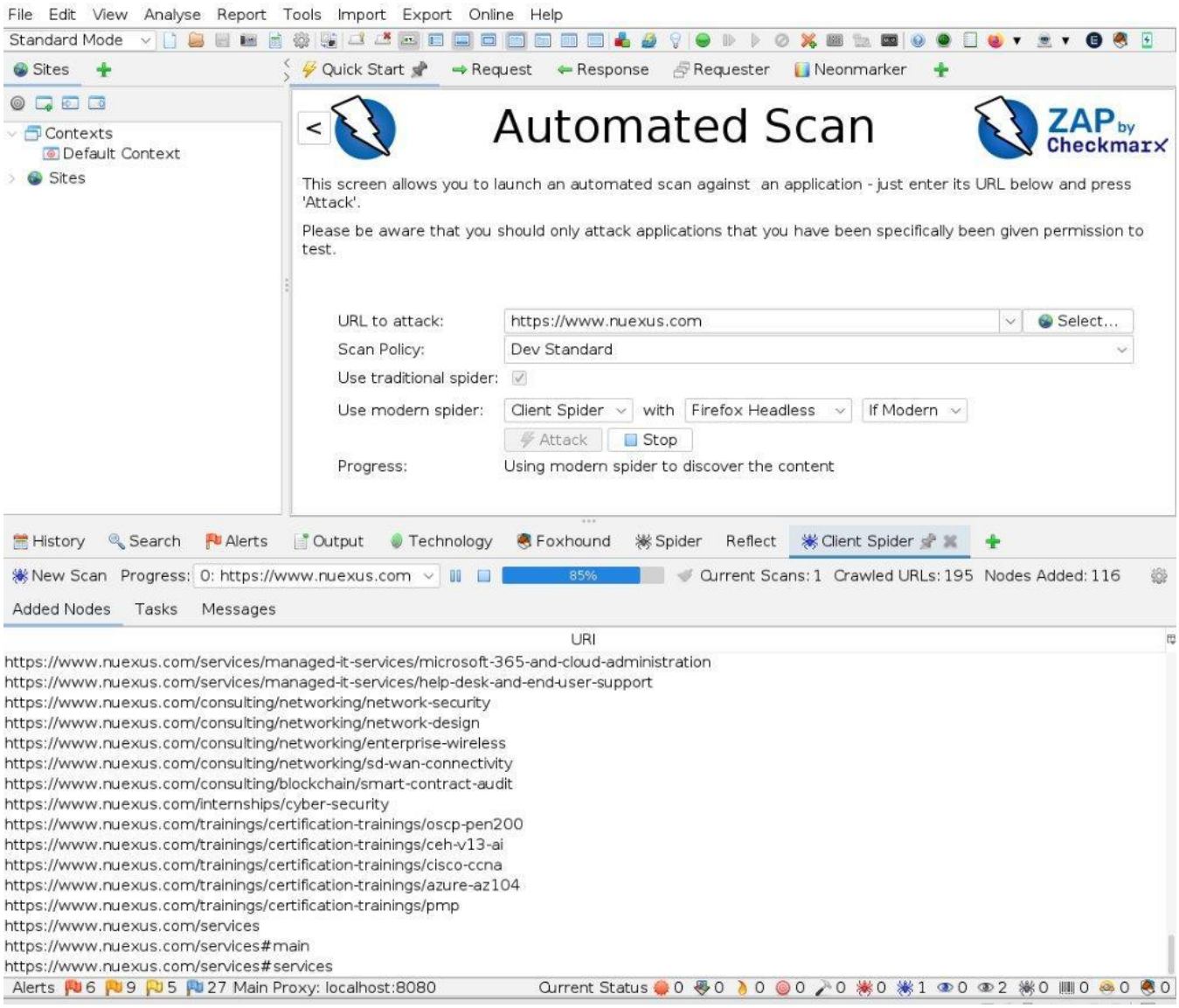


Figure 4.6: OWASP ZAP Automated Scan utilizing headless Firefox AJAX spider across 195 URLs.

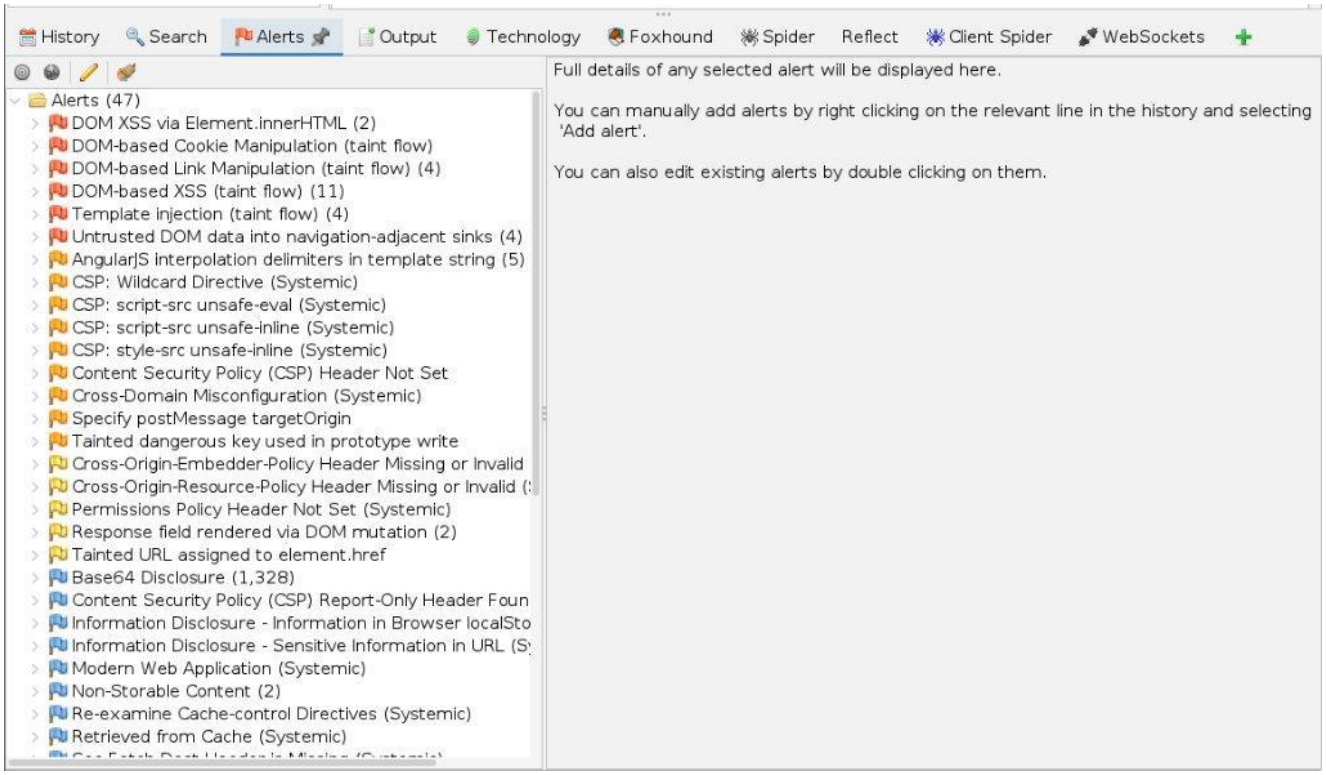


Figure 4.7: OWASP ZAP Alerts tree displaying 47 total vulnerabilities (DOM XSS, taint flows, CSP).

6. Strategic Hardening Recommendations

- **Remediate Content Security Policy (CSP):** Remove 'unsafe-inline' and 'unsafe-eval' directives from Content-Security-Policy. Implement cryptographic nonces (nonce-...) or SHA-256 script hashes for necessary inline logic.
- **Restrict CORS Preflight Directives:** Replace 'Access-Control-Allow-Origin: *' with an explicit whitelist of trusted frontend origins to prevent unauthorized cross-origin data extraction on API routes.
- **Sanitize Client DOM Sinks:** Refactor React/Next.js components flagged by ZAP's taint analysis. Replace direct Element.innerHTML assignments with safe text assignment (textContent) or DOMPurify sanitization.
- **Renew Origin SSL Certificates:** Resolve the HTTP 526 errors on api.nuexus.com, assessments.nuexus.com, and recruit.nuexus.com by provisioning valid Cloudflare Origin CA certificates.
- **Enforce Robots Noindex Directives:** Apply 'X-Robots-Tag: noindex, nofollow' HTTP response headers on /playbooks/ and application subdomains to prevent unauthorized search engine discovery.